



TechBiz Academy

Week 4_Task 12

**OWASP Top 10 — Web Vulnerabilities
Overview**

Submitted By

Ali Hamza

Registration No

TBS-2026-017

Course

Ethical Hacking Internship

Submission Date

26 July 2026

Organization

TechBizz Security

Table of Contents

1. Introduction
2. Objectives
3. Resources Used
4. OWASP Top 10 (2021)
5. Detailed Study of the Top Three Vulnerabilities
6. Real-World Breach Examples
7. Mapping DVWA Vulnerabilities to OWASP Categories
8. Learning Outcome
9. Conclusion
10. References

1. Introduction

Web application security is one of the most important areas of cybersecurity. Every day, organizations face threats from attackers attempting to exploit vulnerabilities in web applications. The **OWASP (Open Worldwide Application Security Project) Top 10** is a globally recognized awareness document that identifies the ten most critical security risks affecting web applications.

As part of my Ethical Hacking internship at **TechBizz Security**, I studied the OWASP Top 10 (2021), researched the three most critical vulnerabilities, analyzed real-world cyber incidents, and mapped vulnerabilities from DVWA (Damn Vulnerable Web Application) to the corresponding OWASP categories.

2. Objectives

The objectives of this assignment were:

- To study the OWASP Top 10 (2021).
- To understand the three most critical vulnerabilities in detail.
- To research real-world cyber incidents related to these vulnerabilities.
- To understand how DVWA vulnerabilities map to the OWASP Top 10.
- To improve knowledge of web application security concepts.

3. Resources Used

The following learning resources were used during this assignment:

Reading Resources

- OWASP Top 10 (Official)
- TryHackMe – OWASP Top 10 (2021) Room

Video Resources

- OWASP Top 10 2021 Explained for Beginners
- Web Application Vulnerabilities Explained

4. OWASP Top 10 (2021)

The OWASP Top 10 identifies the most common and critical web application security risks.

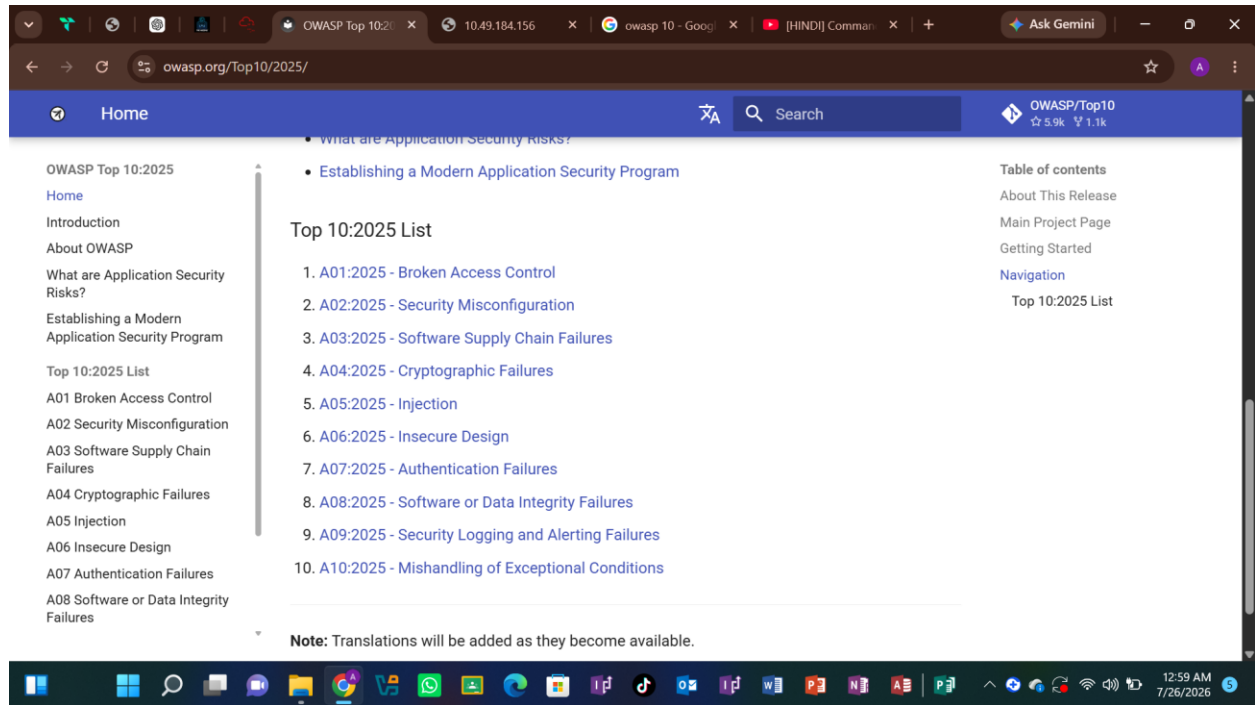


Figure 1: OWASP Top 10 Official Logo





Figure 2: OWASP Top 10 Categories



One-Line Meaning of Each Category

No.	OWASP Category	Meaning
A01	Broken Access Control	Users gain unauthorized access to resources or functions.
A02	Cryptographic Failures	Sensitive information is exposed because encryption is missing or implemented incorrectly.
A03	Injection	Untrusted user input is executed as commands or database queries.
A04	Insecure Design	Security flaws exist due to insecure application design.
A05	Security Misconfiguration	Improper security settings expose the application to attacks.
A06	Vulnerable and Outdated Components	Using unsupported software introduces known vulnerabilities.

No.	OWASP Category	Meaning
A07	Identification and Authentication Failures	Weak authentication mechanisms allow unauthorized access.
A08	Software and Data Integrity Failures	Applications fail to verify the integrity of software or data.
A09	Security Logging and Monitoring Failures	Poor logging delays attack detection and incident response.
A10	Server-Side Request Forgery (SSRF)	Attackers force the server to send unauthorized requests.

5. Detailed Study of the Top Three Vulnerabilities

A01: Broken Access Control

Description

Broken Access Control occurs when an application does not properly enforce authorization rules. This allows users to perform actions or access information beyond their assigned permissions.

Common Examples

- Accessing another user's profile
- Viewing administrator pages without authorization
- Insecure Direct Object References (IDOR)

Impact

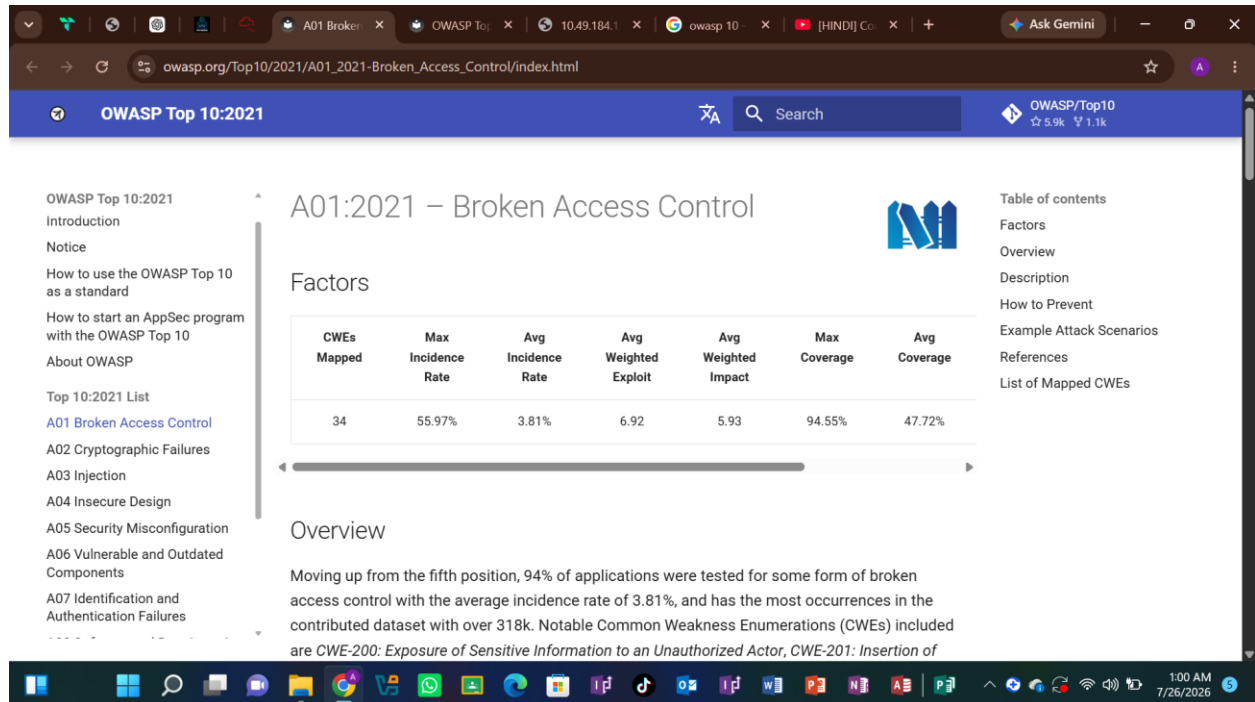
- Unauthorized access
- Privilege escalation
- Data theft
- Data modification

Prevention

- Implement server-side authorization.
- Apply the Principle of Least Privilege.
- Validate every request before granting access.



Figure 3: Broken Access Control (OWASP)



Real-World Example

Facebook "View As" Security Incident (2018)

Facebook disclosed a security vulnerability within its "View As" feature that allowed attackers to steal user access tokens. Approximately **50 million user accounts** were affected before the issue was resolved.



Figure 4: Facebook Official Security Update

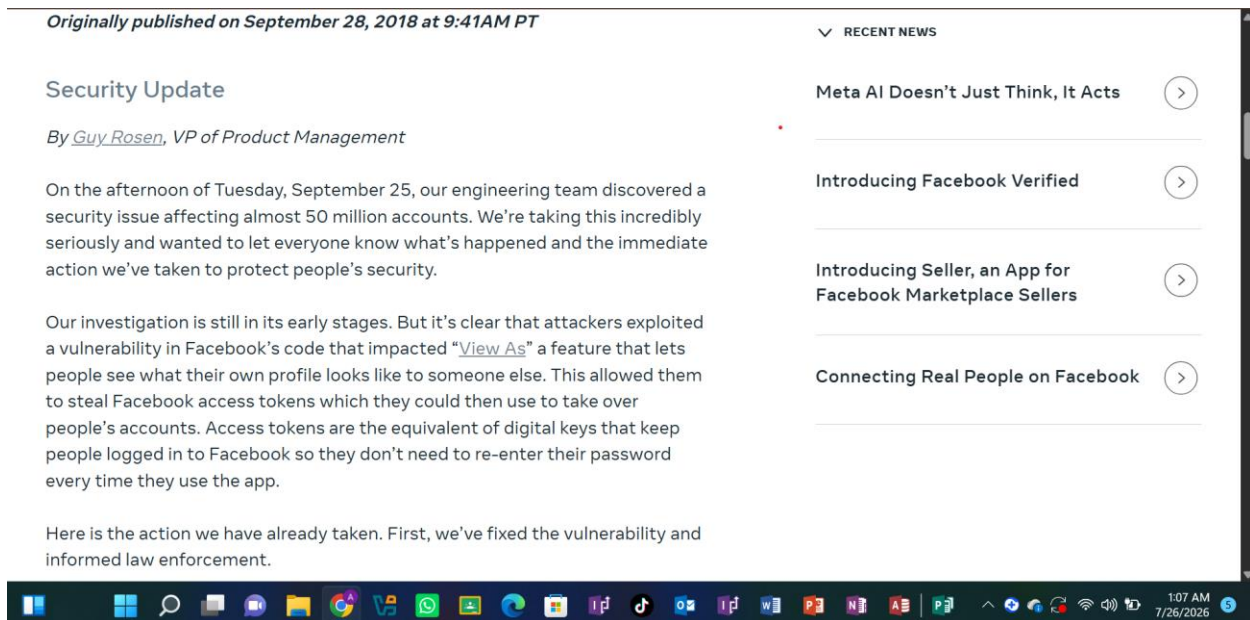


Figure 5: Facebook Security Incident News



A02: Cryptographic Failures

Description

Cryptographic Failures occur when sensitive information is not adequately protected due to weak encryption, poor key management, or insecure communication protocols.

Common Examples

- Storing passwords in plain text
- Weak encryption algorithms
- HTTP communication instead of HTTPS

Impact

- Exposure of confidential information
- Identity theft
- Financial fraud
- Regulatory violations

Prevention

- Encrypt sensitive information.
 - Use HTTPS/TLS.
 - Store passwords using bcrypt or Argon2.
 - Manage encryption keys securely.
-



Figure 6: Cryptographic Failures Description

OWASP Top 10:2021 Notice

How to use the OWASP Top 10 as a standard

How to start an AppSec program with the OWASP Top 10

About OWASP

Top 10:2021 List

A01 Broken Access Control

A02 Cryptographic Failures

A03 Injection

A04 Insecure Design

A05 Security Misconfiguration

A06 Vulnerable and Outdated Components

A07 Identification and Authentication Failures

A08 Software and Data Integrity Failures

A09 Security Logging and

Description

The first thing is to determine the protection needs of data in transit and at rest. For example, passwords, credit card numbers, health records, personal information, and business secrets require extra protection, mainly if that data falls under privacy laws, e.g., EU's General Data Protection Regulation (GDPR), or regulations, e.g., financial data protection such as PCI Data Security Standard (PCI DSS). For all such data:

- Is any data transmitted in clear text? This concerns protocols such as HTTP, SMTP, FTP also using TLS upgrades like STARTTLS. External internet traffic is hazardous. Verify all internal traffic, e.g., between load balancers, web servers, or back-end systems.
- Are any old or weak cryptographic algorithms or protocols used either by default or in older code?
- Are default crypto keys in use, weak crypto keys generated or re-used, or is proper key management or rotation missing? Are crypto keys checked into source code repositories?
- Is encryption not enforced, e.g., are any HTTP headers (browser) security directives or headers missing?
- Is the received server certificate and the trust chain properly validated?
- Are initialization vectors ignored, reused, or not generated sufficiently secure for the

Table of contents

- Factors
- Overview
- Description
- How to Prevent
- Example Attack Scenarios
- References
- List of Mapped CWEs



Figure 7: Cryptographic Failures Overview

OWASP Top 10:2021 Notice

How to use the OWASP Top 10 as a standard

How to start an AppSec program with the OWASP Top 10

About OWASP

Top 10:2021 List

A01 Broken Access Control

A02 Cryptographic Failures

A03 Injection

A04 Insecure Design

A05 Security Misconfiguration

A06 Vulnerable and Outdated Components

A07 Identification and Authentication Failures

A08 Software and Data Integrity Failures

A02:2021 – Cryptographic Failures

Factors

CWEs Mapped	Max Incidence Rate	Avg Incidence Rate	Avg Weighted Exploit	Avg Weighted Impact	Max Coverage	Avg Coverage
29	46.44%	4.49%	7.29	6.81	79.33%	34.85%

Overview

Shifting up one position to #2, previously known as *Sensitive Data Exposure*, which is more of a broad symptom rather than a root cause, the focus is on failures related to cryptography (or lack thereof). Which often lead to exposure of sensitive data. Notable Common Weakness Enumerations (CWEs) included are CWE-259: *Use of Hard-coded Password*, CWE-327: *Broken or*

Real-World Example

Equifax Data Breach (2017)

The Equifax data breach exposed sensitive personal information belonging to approximately **147 million individuals**. The incident emphasized the importance of protecting confidential information and maintaining strong security practices.



Figure 8: Equifax Official Security Announcement

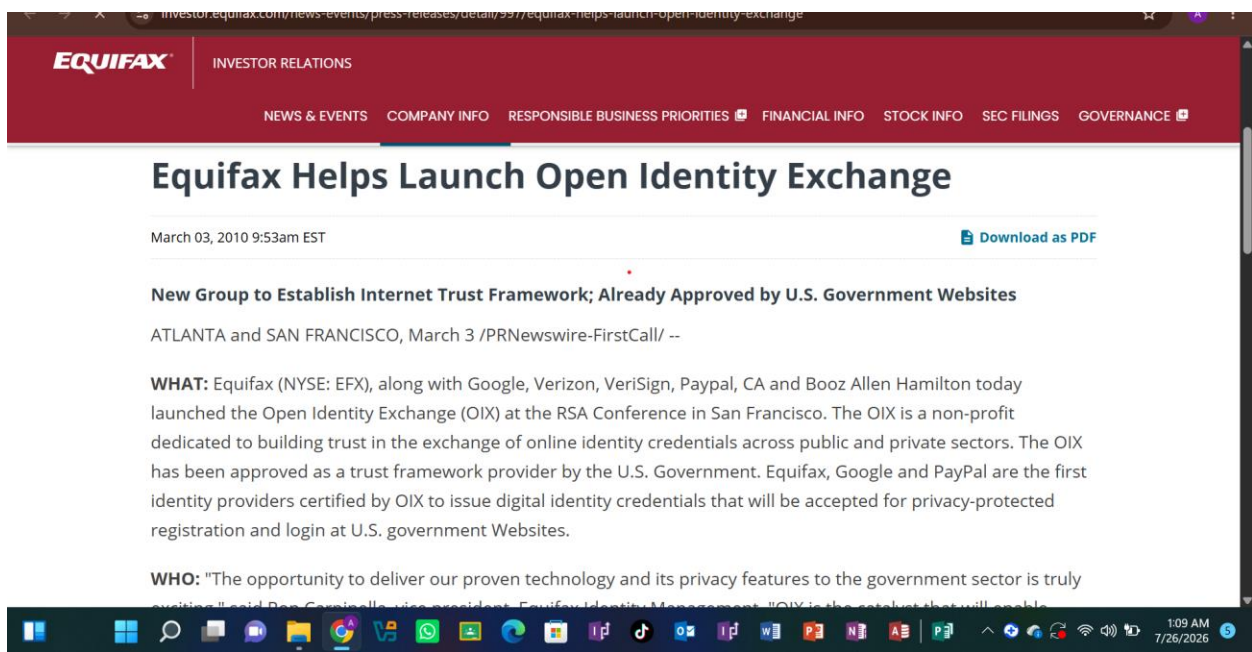


Figure 9: Equifax Breach Report



A03: Injection

Description

Injection vulnerabilities occur when an application processes untrusted input as part of a command or database query without proper validation.

Common Types

- SQL Injection
- Command Injection
- LDAP Injection
- NoSQL Injection

Impact

- Unauthorized database access
- Data leakage
- Data modification

- Potential remote code execution

Prevention

- Use prepared statements.
- Validate user input.
- Apply parameterized database queries.
- Use secure coding practices.



Figure 10: Injection Vulnerability Description

OWASP Top 10:2021

How to use the OWASP Top 10 as a standard

How to start an AppSec program with the OWASP Top 10

About OWASP

Top 10:2021 List

A01 Broken Access Control

A02 Cryptographic Failures

A03 Injection

A04 Insecure Design

A05 Security Misconfiguration

A06 Vulnerable and Outdated Components

A07 Identification and Authentication Failures

A08 Software and Data Integrity Failures

A09 Security Logging and Monitoring Failures

Description

An application is vulnerable to attack when:

- User-supplied data is not validated, filtered, or sanitized by the application.
- Dynamic queries or non-parameterized calls without context-aware escaping are used directly in the interpreter.
- Hostile data is used within object-relational mapping (ORM) search parameters to extract additional, sensitive records.
- Hostile data is directly used or concatenated. The SQL or command contains the structure and malicious data in dynamic queries, commands, or stored procedures.

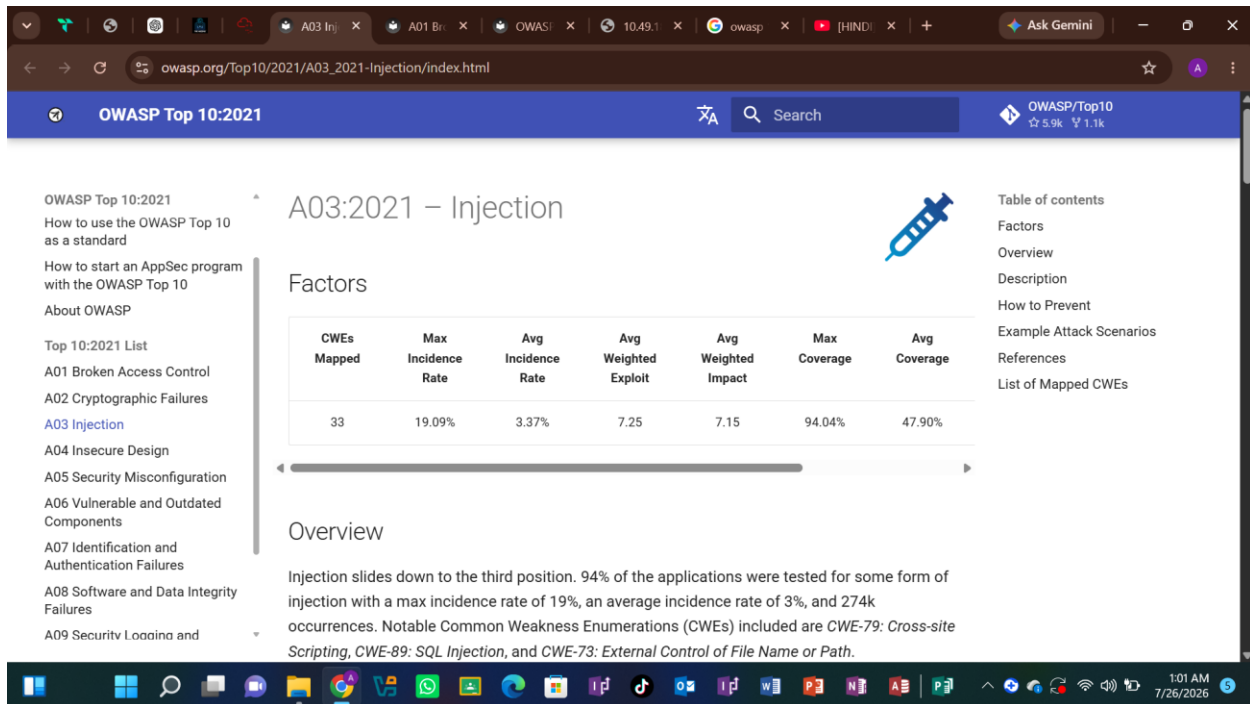
Some of the more common injections are SQL, NoSQL, OS command, Object Relational Mapping (ORM), LDAP, and Expression Language (EL) or Object Graph Navigation Library (OGNL) injection. The concept is identical among all interpreters. Source code review is the best method of detecting if applications are vulnerable to injections. Automated testing of all parameters, headers, URL, cookies, JSON, SOAP, and XML data inputs is strongly encouraged. Organizations can include static (SAST), dynamic (DAST), and interactive (IAST) application security testing tools into the CI/CD pipeline to identify introduced injection flaws before production deployment.

Table of contents

- Factors
- Overview
- Description**
- How to Prevent
- Example Attack Scenarios
- References
- List of Mapped CWEs



Figure 11: Injection Overview



Real-World Example

TalkTalk Data Breach (2015)

Attackers exploited a SQL Injection vulnerability in TalkTalk's website, compromising the personal information of more than **150,000 customers**.

Figure 12: TalkTalk SQL Injection Breach



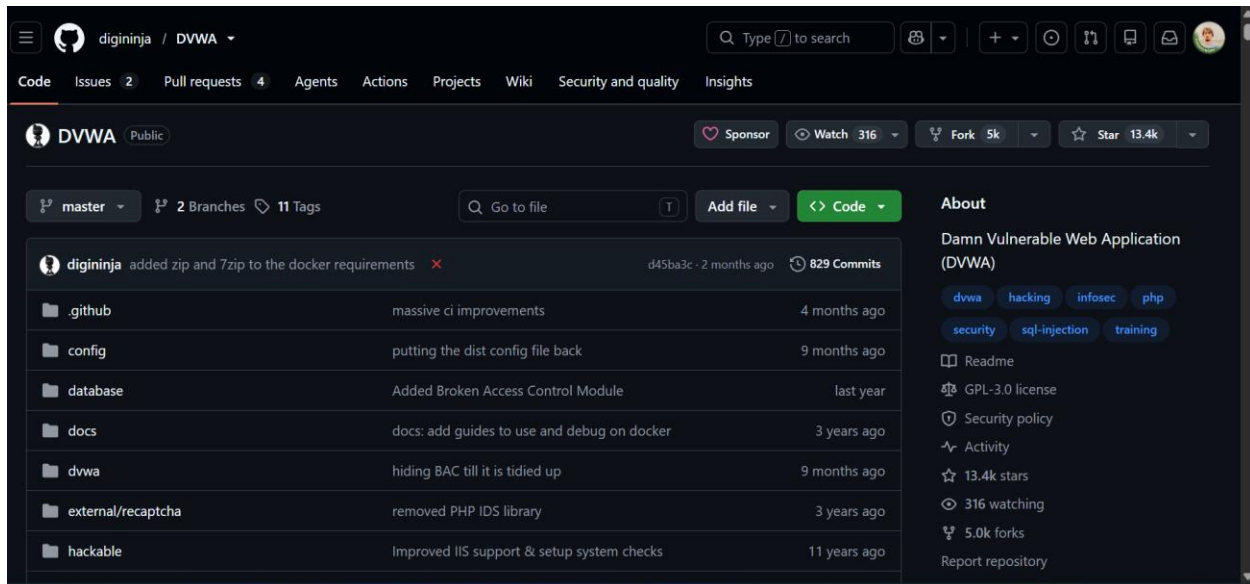
6. Mapping DVWA Vulnerabilities to OWASP Categories

DVWA (Damn Vulnerable Web Application) is an intentionally vulnerable web application used for cybersecurity education and ethical hacking practice.

DVWA Module	OWASP Category	Description
SQL Injection	A03 – Injection	User input manipulates SQL queries.
Blind SQL Injection	A03 – Injection	SQL Injection without displaying database output.
Command Injection	A03 – Injection	Executes operating system commands.
Reflected XSS	A03 – Injection	JavaScript executes in the victim's browser.
Stored XSS	A03 – Injection	Malicious scripts are permanently stored.
DOM XSS	A03 – Injection	Client-side JavaScript processes untrusted input.
File Inclusion	A01 – Broken Access Control	Unauthorized file access.
CSRF	A01 – Broken Access Control	Unauthorized requests performed using a victim's session.
File Upload	A05 – Security Misconfiguration	Insecure upload configuration.
Brute Force	A07 – Identification and Authentication Failures	Weak authentication enables password guessing.
Weak CAPTCHA	A07 – Identification and Authentication Failures	CAPTCHA protection is ineffective.



Figure 13: DVWA Official GitHub Repository



7. Learning Outcome

Through this assignment, I learned:

- The importance of the OWASP Top 10 in web application security.
- The causes and impacts of Broken Access Control, Cryptographic Failures, and Injection.
- How real-world organizations have been affected by these vulnerabilities.
- How DVWA demonstrates common web application security flaws in a safe learning environment.
- The importance of secure coding, proper authentication, encryption, and access control in protecting web applications.

8. Conclusion

The OWASP Top 10 provides a valuable framework for understanding the most significant web application security risks. Among these, Broken Access Control, Cryptographic Failures, and Injection remain some of the most common and dangerous vulnerabilities affecting organizations worldwide. Studying these security risks, reviewing real-world breach examples, and

understanding how they relate to DVWA has strengthened my understanding of ethical hacking and secure web application development. This knowledge forms an essential foundation for conducting ethical security assessments and promoting secure software development practices.

9. References

1. OWASP Foundation. *OWASP Top 10 – 2021*.
2. OWASP Foundation. *A01: Broken Access Control*.
3. OWASP Foundation. *A02: Cryptographic Failures*.
4. OWASP Foundation. *A03: Injection*.
5. TryHackMe. *OWASP Top 10 – 2021 Room*.
6. Meta. *Facebook Security Update (2018)*.
7. Equifax. *Cybersecurity Incident (2017)*.
8. BBC News. *TalkTalk Data Breach (2015)*.
9. DVWA Official GitHub Repository.
10. YouTube. *OWASP Top 10 2021 Explained for Beginners*.
11. YouTube. *Web Application Vulnerabilities Explained*.
12. TryHackMe — *OWASP Top 10 - 2021 (free room)*
13. *OWASP Top 10 (official)*